

PHISHING AWARENESS SIMULATION

End-User Security Report

Prepared by: Hellen Babawale

Date: September 6, 2026

Tool used: Gophish (self-hosted, open-source phishing simulation framework)

1. Executive Summary

This report documents a controlled, self-administered phishing awareness simulation conducted as part of a hands-on cybersecurity portfolio project. The purpose of the exercise was to build practical experience with the full lifecycle of a phishing simulation campaign from infrastructure setup through email delivery, tracking, results analysis, and reporting, using the same tools and methodology employed by security awareness teams in real organizations.

The simulation targeted a single recipient (the report author, acting as the sole test subject) using a pretext themed around account security verification. The recipient opened the email, clicked the embedded link, and submitted fictitious credentials on a simulated login page within approximately 1 minute and 41 seconds of the email being sent, completing the full attack chain that a real phishing campaign is designed to achieve.

This case study format, while limited to a single data point, still demonstrates the mechanics of how phishing succeeds, how quickly it can succeed, and what indicators should raise suspicion before a link is ever clicked.

2. Methodology

The simulation was built and run using Gophish, hosted locally on a Kali Linux virtual machine. The following Components were configured:

- I. Sending Profile: Gmail SMTP relay, authenticated using an app-specific password.
- II. Email Template: A security-alert pretext ("Action Required: Verify Your Account") using urgency-based language and a tracked link.
- III. Landing Page: A simulated login form requesting an email address and password, with submitted-data capture enabled.
- IV. Target Group: One recipient (the report author), used with informed self-consent.
- V. Tracking: Gophish's built-in event tracking for Email Sent, Email Opened, Clicked Link, and Submitted Data stages.

No real credentials were collected or stored at any point; all submitted values were fictitious test data entered specifically for this exercise.

3. Results

Metric	Value	Notes
Targets	1	Self-administered pilot run
Email sent	2026-09-06, 18:27:24 UTC	Delivered via Gmail SMTP relay
Highest stage reached	Submitted Data	Full chain: sent → opened → clicked → submitted
Data Submitted	2026-09-06, 18:29:05 UTC	Credentials entered were fictitious test values
Time to compromise	1 min 41 sec	Elapsed time from send to data submission
Reported as phishing	No	No reporting mechanism used during this run

The recipient progressed through every stage of the simulated attack chain in under two minutes, mirroring real-world phishing outcomes, where a convincing pretext combined with urgency language frequently overrides usual caution.

4. Red Flags Analysis

Urgency language ("Action Required," "unusual activity") designed to short-circuit careful review.

A generic greeting ("Hi,") rather than a personalized one. This is common in mass phishing sends.

A request to "verify your identity" via an embedded link rather than through a known, bookmarked site.

A login page that did not match the real appearance, domain, or certificate of the purported service.

No prior context or expectation of receiving a security alert of this kind.

5. Recommendations

Pause before acting on urgency-driven security emails, verify independently by navigating directly to the service.

Check sender address and landing page domain carefully before entering credentials.

Enable multi-factor authentication so a submitted password alone isn't enough for takeover.
Use a password manager, it won't auto-fill on a spoofed domain, a useful built-in tell.

Build a habit of reporting suspicious emails to IT/security rather than deleting them.

For organizations: run repeated, varied simulations over time rather than a one-off test

6. Conclusion

This exercise provided hands-on experience configuring and running a full phishing simulation campaign end-to-end, and produced a concrete, time-stamped illustration of how quickly a phishing attempt can succeed with a convincing pretext. The findings reinforce the value of user awareness training, technical controls like MFA, and a low-friction reporting culture, no single layer is sufficient on its own.